Security Audit

OWASP Top 10 + AWS Well-Architected (security pillar)

Proyecto	monoulabs.ai landing (rladron-rodia/landing_contacto)
Version	v3.1.0
Fecha	2026-05-09
Auditor	Auditoria automatizada (Claude agent)
AWS Account	325907670798 (us-east-1)
Scope	OWASP Top 10 + AWS Well-Architected (security pillar)

1. Executive Summary

Overall posture: GOOD with caveats. The stack is materially better than 90% of solo-dev SaaS deployments: customer-managed KMS, scoped IAM policies, private subnets, WAF in front of CDN, secrets out of code, systemd hardening, rate limiting on every sensitive endpoint, magic-link recovery built signed-stateless instead of with sessions, hmac.compare_digest on auth, escape on email HTML. Migration from Render to AWS removed several latent risks (SMTP/HTTP-only secrets, free-tier provider lock-in, untracked IAM).

The remaining gaps are concentrated in three areas: (a) the deploy IAM user holds `AdministratorAccess` (acknowledged as Fase 9 pending), (b) authentication is still a single shared static `ADMIN_TOKEN` with no rotation policy or per-user audit, and (c) detection/observability is minimal — no CloudWatch alarms, no GuardDuty, no centralized logging beyond the EC2 journal. None of these are exploits-today, but each is a "first move from compromise to incident" if something else slips.

Findings count by severity

Severity	Count
Critical	0
High	4
Medium	10
Low	9
Info /■ Positive	14
Total findings	**23 actionable + 14 positives**

Top 5 priorities (severity × likelihood × ease-of-fix)

1. **H-01 — `monou-landing-deployer` holds AdministratorAccess.** Single IAM user with full account access; if its keys leak (laptop theft, repo accident, dotfiles backup) the entire account is owned. Fase 9 already on roadmap; should be promoted to immediate.
2. **H-02 — Single shared `ADMIN_TOKEN` with no rotation, MFA, or per-user trail.** Bearer-token auth is correctly compared via `hmac.compare_digest`, but token reuse across collaborators, no expiry, and recovery email gated by inbox access are real risks. v3.2.0 multi-user is already planned — accelerate.
3. **H-03 — Public S3 bucket for images served direct from `*.s3.amazonaws.com`.** `monou-landing-images-prod` is public via bucket policy and served not behind CloudFront/WAF, so it bypasses rate-limiting, gets no edge caching, and content is uploaded by the admin endpoint without MIME re-validation at S3 layer. Minor cost/abuse exposure.
4. **H-04 — Stale env-var check in `s3_uploader.is_configured()` will reject uploads on EC2.** `is_configured()` requires `AWS_ACCESS_KEY_ID` / `AWS_SECRET_ACCESS_KEY` env vars, but on EC2 the instance role provides creds via IMDS (no env vars are set). Image upload endpoint will return 500 in prod. Functional + correctness bug.
5. **M-01 / observability cluster** — No CloudWatch alarms (5xx, ALB latency, RDS connections), no GuardDuty, no S3/ALB access logging enabled, no CloudTrail data-events. Detection-and-response capability is essentially zero today; documented as v3.3.0 (Fase 8) but should not slip much further.

2. OWASP Top 10 (2021) Mapping

OWASP	Status	Evidence	Finding(s)
A01 — Broken Access Control	Partial	`_■is_■admin()` gates every `/■api/■admin/■*` route; `hmac.■compare_■digest` used; no IDORs found in CRUD endpoints (operate on whitelisted slugs/■keys); CORS scoped to `ALLOWED_■ORIGIN`; admin UI shipped from same origin via S3+CloudFront.■ **Gaps:**■ single shared token, no per-■user audit, recovery flow lets anyone with MAIL_■TO inbox access pivot to full admin.	H-■02, M-■02
A02 — Cryptographic Failures	Mitigated	TLS 1.■2_■2021 min on CloudFront; ACM-■managed certs; RDS encrypted at rest with customer-■managed KMS (`alias/■monou-■key-■01`); Secrets Manager encrypted with same key; `psycopg` connect appends `sslmode=■require`; HMAC-■SHA256 on recovery tokens; `secrets.■token_■urlsafe(16)` for nonce.■ **Minor:**■ no HSTS header at backend, no key rotation schedule for KMS or secrets.	L-■01, L-■02
A03 — Injection	Mitigated	All SQL via psycopg parameterized queries (`%s` placeholders, never f-■string interpolation of user input).■ No `eval`/■`exec`/■`os.■system` calls on user input.■ Subject line stripped of CRLF (header-■injection defense).■ HTML email body uses `html.■escape(quote=■True)` on every interpolation.	— (positive)
A04 — Insecure Design	Partial	Honeypot field (`website`) in form, server-■side max body, per-■field length limits, magic-■link expiry 15 min, stateless signed token, multi-■layer rate limits.■ **Gaps:**■ no CSRF token on admin POSTs (compensated only by CORS + bearer auth); no detection signaling on repeated failed admin auth (rate limit silently 429s but no alert); idempotent S3 keys hashed only by output PNG bytes (collisions on attacker-■crafted same-■hash PNG would overwrite — extremely low likelihood, content-■hash 8 hex chars =■ 32 bits, brittle for adversarial).	M-■03, M-■04, L-■03

OWASP	Status	Evidence	Finding(s)
A05 — Security Misconfiguration	Partial	systemd hardening present (NoNewPrivileges, ProtectHome, etc.■).■ Headers `X-■Content-■Type-■Options`, `X-■Frame-■Options:■ DENY`, `Referrer-■Policy` set on every API response.■ WAF enabled with managed rule sets.■ **Gaps:**■ no HSTS, no CSP on landing/■admin (admin loads Tailwind from CDN over HTTPS but inline scripts present), default `ALLOWED_■ORIGIN` falls back to `*` in code if not set, gunicorn `-■-■access-■logfile -■` ships only to stdout (journal), no centralized log ingestion.■ `s3_■uploader.■is_■configured()` enforces stale env-■var schema (H-■04).■ Admin loads JS from `cdnjs.■cloudflare.■com`, `cdn.■tailwindcss.■com`, `fonts.■googleapis.■com` without SRI.	H-■04, M-■05, M-■06, M-■07
A06 — Vulnerable & Outdated Components	Mitigated	`requirements.■txt` is pinned.■ Pillow 12.■2.■0 (current, post-■CVE bump).■ Flask 3.■1.■3, gunicorn 22, Flask-■Cors 6, psycopg 3.■2.■3, boto3 1.■42.■97 — all current at audit date.■ No SBOM file or automated CVE scanning (Dependabot etc.■) detected; reliance on manual cadence.	M-■08
A07 — Identification & Auth Failures	Partial	Bearer token compared with timing-■safe HMAC.■ Rate limits `5/■min, 30/■h, 100/■day` on contact, `30/■h` on uploads, `3/■h, 1/■5min` on recovery request, `10/■h, 5/■5min` on exchange — strong.■ Admin token survives tab refresh only in JS memory (good — XSS defense in depth).■ **Gaps:**■ single shared token, no per-■user identity, no MFA, no expiry, no logout revocation server-■side (clearToken just zeroes the JS var, token still valid until manually rotated).■ Recovery email =■ "if you have inbox, you have admin" with no secondary factor.	H-■02, M-■09
A08 — Software & Data Integrity Failures	Partial	Deploy artifacts go through versioned S3 bucket; install.■sh validates artifact structure before swap; install does atomic stage→swap with .■old retained.■ **Gaps:**■ artifacts not signed, no checksum verification at install time (anyone with PutObject on `monou-■deploy-■artifacts-■prod` could substitute), CloudFront Function code not validated in CI, no GitHub branch protection /■ required reviews documented, deploy IAM user with admin perms can also write to artifacts bucket.	M-■10, L-■04

OWASP	Status	Evidence	Finding(s)
A09 — Logging & Monitoring Failures	Gap	gunicorn access log + journalctl-■only.■ No CloudWatch alarms, no GuardDuty, no VPC Flow Logs documented, no S3 access logs, no ALB access logs to S3, no CloudTrail data-■events on critical buckets, no log retention beyond systemd journal default (~weeks).■ Failed admin auth not separately logged or alerted.■ The Disaster Recovery doc cites CloudTrail "default 90 days" but no archival path.■ v3.■3.■0 (Fase 8) explicitly future work.	M-■01, L-■05, L-■06
A10 — SSRF	Mitigated	The only outbound HTTP from the backend is `boto3` (AWS endpoints, controlled) and the legacy `force_■ipv4` ctx for Resend (now dead code post-■v3.■1.■0).■ User input is never used to construct an outbound URL.■ IMDSv2 token usage in `start-■monou.■sh` (correct hop-■limited variant).■ No URL-■fetching feature exists.	— (positive)

3. AWS Infrastructure Security

3.1 IAM

ID	Severity	Finding
H-■01	High	`monou-■landing-■deployer` IAM user has `AdministratorAccess`.■ Single point of catastrophic failure.■ Acknowledged as Fase 9 deferred work.■ **Action:**■ scope to actual API surface (S3 deploy bucket, SSM SendCommand, ELBv2 describe, EC2 describe — ~12 actions total).■ Build the policy from CloudTrail-■of-■last-■30d as documented.
L-■07	Low	No IAM Access Analyzer enabled or referenced.■ Free service that flags external-■account access on resources.
L-■08	Low	No documented Access Key rotation schedule for `monou-■landing-■deployer`.■ Disaster recovery checklist mentions rotating "every 90d in Fase 9" but no automation.
POSITIVE	—	EC2 instance role `monou-■backend-■ec2-■role` is exemplary:■ 5 inline policies all resource-■scoped (specific KMS key, specific 2 secret ARNs, specific SSM path `/■monou/■prod/■*`, specific S3 buckets, specific 2 SES identity ARNs).■ Exactly the model AWS recommends.
POSITIVE	—	No long-■lived AWS access keys in the application.■ boto3 picks up IMDSv2 instance-■role creds.■ `AWS_■ACCESS_■KEY_■ID`/`■AWS_■SECRET_■ACCESS_■KEY` env vars not set in `start-■monou.■sh` (good).

3.2 KMS

ID	Severity	Finding
L-■01	Low	No documented automatic key rotation enabled on `alias/■monou-■key-■01`.■ Customer-■managed keys support 1-■year rotation as a single API call.
L-■09	Low	Key is single-■region.■ DR doc flags this:■ "considerar replicar a otra región o cambiar a key sin schedule deletion.■" Replicating doubles cost (~$1) but eliminates single-■region SPOF for encrypted secrets.
POSITIVE	—	Customer-■managed CMK (not AWS-■managed) is the correct choice for production — gives full audit, deletion control, and rotation policy.■ KMS key policy presumably scoped to specific principals (not audited directly here).

3.3 VPC, Network & Security Groups

ID	Severity	Finding
L-■05	Low	VPC Flow Logs not documented as enabled.■ Free-■tier-■friendly when shipped to S3 with lifecycle.■ Critical for post-■incident forensics.
L-■10	Low	Backend SG egress not documented.■ Default AWS SG egress is 0.■0.■0.■0/■0 all ports, which is fine functionally but for hardening should be restricted to AWS public IP ranges (S3, SES, Secrets Manager endpoints) or routed via VPC endpoints.
L-■11	Low	No VPC endpoints (S3 Gateway, Secrets Manager Interface, SSM Interface) — all AWS API calls leave through NAT to public internet.■ Cost:■ NAT processing fees.■ Security:■ traffic visible to AWS-■managed-■but-■not-■private path.
POSITIVE	—	Private subnets host EC2 + RDS; ALB-■only ingress on backend SG:■8080; backend-■SG-■only ingress on DB SG:■5432.■ Textbook.
POSITIVE	—	RDS `-■-■no-■publicly-■accessible`, KMS-■encrypted at rest, sslmode=■require enforced client-■side.

3.4 Secrets & Parameters

ID	Severity	Finding
M-■11	Medium	Secrets Manager has no automatic rotation configured for `monou/■prod/■database` or `monou/■prod/■app`.■ RDS supports turnkey rotation Lambda; would automate the ADMIN_■TOKEN/■RESEND_■API_■KEY/■RDS-■password recurring refresh.
L-■12	Low	`FLASK_■SECRET_■KEY` strength validated only as `len(secret) >=■ 16` bytes.■ With 16 bytes raw it's fine; if a human sets it to a 16-■char passphrase it's much weaker.■ Suggest enforce ≥ 32 random bytes.
POSITIVE	—	Secrets all encrypted with customer KMS key, retrieved at boot via wrapper, never written to disk in artifact, not in env-■var defaults.■ SSM Parameter Store used correctly for non-■secret config.

3.5 S3

	Severity	Finding	
	High	`monou-■landing-■images-■prod` is served directly via `https:■/■/■<bucket>.■s3.■us-■east-■1.■amazonaws.■com/■.■.■.■` (see `s3_■uploader.■upload()` return URL).■ This bucket:■ (a) does not sit behind CloudFront/■WAF, (b) gets no edge caching despite `Cache-■Control:■ immutable`, (c) bypasses rate-■limiting and IP-■reputation block on dataset abuse.■ Consider fronting with the existing CloudFront distribution (new behavior `/■images/■*`) or a second CDN distribution.■ Also, the bucket policy (assumed public-■read) grants list-■permissions risks if not exactly scoped to GetObject.	
	Medium	Image upload endpoint validates MIME via Pillow (good) but stores `ContentType` parameter from server side (`image/■png` /■ `image/■webp`) — fine — yet S3 has no Object Lambda or `Content-■Disposition:■ attachment` enforcement.■ A confused-■deputy scenario where future code paths upload non-■image as "image/■*" would serve attacker content from a trusted-■looking domain.■ Add bucket policy restriction `s3:■x-■amz-■content-■type` ∈ image/■png	image/■webp.
	Low	`monou-■landing-■images-■prod` versioning status not stated in DR doc ("verificar versionado").■ Should be enabled for rollback parity with the other 2 buckets.	
	Low	No Block Public Access at account level documented.■ With `monou-■landing-■images-■prod` intentionally public, account-■level BPA is off; this means a future bucket created without explicit `BlockPublicAcls=■true` defaults could leak silently.	
	—	Frontend bucket `monoulabs-■landing-■prod` is private with OAC.■ `monou-■deploy-■artifacts-■prod` is private with versioning + 90d lifecycle.■ Both correct.	

3.6 Backups & Recovery

ID	Severity	Finding
M-■13	Medium	RDS automated backups retention =■ 7 days (default).■ DR runbook flags this:■ "Considerar extender a 30d.■" For a contact-■form/■CMS DB the 7-■day window is the gap between detecting silent corruption and losing the last known good.
M-■14	Medium	No PITR (Point-■In-■Time-■Recovery) cadence beyond the 7-■day automated.■ Roadmap mentions "habilitar PITR más allá de 7d" — that's just the same `BackupRetentionPeriod` knob; needs a number.
L-■15	Low	Manual snapshot policy is "before major changes" (advisory in DR doc).■ No automation, no monthly cron.

ID	Severity	Finding
POSITIVE	—	DR runbook is comprehensive — 8 scenarios with command lines, escape hatches for AWS-■account-■compromise, and a "regenerate `monou-■vars.■sh` from API" recipe.■ Materially above industry baseline.
POSITIVE	—	S3 versioning enabled on frontend + deploy artifacts.■ Atomic deploy retains `.■old` for instant rollback.

3.7 Logging & Monitoring

ID	Severity	Finding
M-■01	Medium	No CloudWatch Alarms.■ Recommended minimum:■ ALB 5xx-■rate, ALB target unhealthy, EC2 StatusCheckFailed, RDS CPU >80%, RDS FreeStorageSpace <10%, RDS DatabaseConnections >50% of max, Secrets-■Manager-■API-■error-■rate (rotation pulse), gunicorn 5xx via custom metric filter on log group.■ v3.■3.■0 work.
M-■15	Medium	ALB access logs not enabled (default off).■ To S3 with 30-■day lifecycle =■ pennies; required for any 4xx/■5xx forensic timeline.
L-■06	Low	CloudFront access logs /■ standard logging not documented as enabled.
L-■16	Low	No GuardDuty (~$3/■mo for an account this small).■ Catches IAM-■key-■leak-■elsewhere usage signals, EC2-■instance-■mining, and S3 anomalous-■access.
L-■17	Low	CloudTrail retention set to default 90d.■ DR doc notes "Considerar archivar a S3 long-■term.■" Important for after-■the-■fact audit (e.■g.■, "did anything touch our KMS in the last 6 months").

4. Backend Code Security (`server/app.py`, `db.py`, `s3_uploader.py`, `image_optimizer.py`)

4.1 Input validation

ID	Severity	Finding
POSITIVE	—	`_■validate_■contact_■payload()` is correct:■ required-■field check, type check, per-■field length truncation (not silent — server-■controlled), email regex, honeypot processed correctly (returns 200 without DB write or email — dark-■pattern bot-■confusion).
POSITIVE	—	Body size capped at 16 MB (`MAX_■CONTENT_■LENGTH`) with explicit 413 handler.
POSITIVE	—	Image upload validates:■ format whitelist (PNG/■JPEG/■WEBP/■GIF), max 15 MB raw, max 5000×5000 dims, slug regex `[^a-■z0-■9-■]+ → -■`, folder whitelist (`games/■site-■links/■uploads`), bbox 16-■4000 range.■ Comprehensive.

ID	Severity	Finding
L-■03	Low	Idempotent S3 key uses `hashlib.■sha256(png_■bytes).■hexdigest()[:■8]` — 32 bits of identifier.■ Two non-■malicious images can collide 1-■in-■65k after ~256K uploads (birthday).■ Realistic at this scale:■ very rare.■ Adversarial:■ a poisoner with ADMIN_■TOKEN already controls the upload, so collision attack is moot.■ Consider 16 hex chars (64 bits) anyway — costs nothing.
M-■02	Medium	Admin CRUD endpoints (stats/■games/■links/■delivery/■info/■cta-■tags) accept arbitrary strings into URL fields (`url`, `link_■url`, `image_■url`).■ No validation that the value is `https:■/■/■` or matches an allowlist.■ An admin (or someone using a leaked ADMIN_■TOKEN) can inject `javascript:■` URIs that the frontend renders into anchor `href`.■ The frontend currently uses the URLs in `<a href>` and `<img src>` directly.■ Add `^https?:■/■/■` enforcement server-■side.

4.2 SQL Injection

ID	Severity	Finding
POSITIVE	—	All queries use psycopg parameter substitution (`%s` and named `%(name)s`).■ No f-■string interpolation of user input into SQL.■ The single dynamic SQL piece — column list construction in `list_■*` helpers — uses static, non-■user-■controlled string concatenation (good).

4.3 Email HTML / header injection

ID	Severity	Finding
POSITIVE	—	Every interpolated user value into the HTML email body is `html.■escape(value, quote=■True)`.■ Subject is stripped of CRLF (header-■injection guard).■ Reply-■To is regex-■validated and CRLF-■stripped before being passed to SES.
L-■18	Low	The `body_■text` (plain-■text part) is *not* escaped/■sanitized.■ Plain-■text email is generally non-■rendering, but some clients auto-■link, and a malicious URL in `mensaje` could appear clickable.■ Low impact (recipient is `MAIL_■TO`, an internal-■employee inbox, not a customer).

4.4 CSRF

ID	Severity	Finding
M-■03	Medium	No CSRF token.■ Admin endpoints rely on Bearer token in `Authorization` header (which is *not* automatically attached by browsers cross-■site, so technically immune to classic form-■CSRF).■ However, if the admin token ever moves to a cookie (e.■g.■, for SSO/■multi-■user in v3.■2.■0), CSRF protection becomes mandatory.■ Documented as future-■need.

4.5 File upload validation

POSITIVE	**All checked above. Pillow `validate_and_load` performs decode-then-format-check (not extension-based), bbox clamp prevents memory bombs, content-hash naming prevents path traversal in S3 keys.**

4.6 Error handling info leak

ID	Severity	Finding
POSITIVE	—	`image_■optimizer` deliberately strips Pillow internals from user-■facing message ("imagen corrupta o ilegible" instead of `e.■args[0]`).■ S3 errors → generic "upload a S3 falló".■ `app.■logger.■exception` captures full trace internally.
L-■19	Low	`mark_■status(contact_■id, "failed", "validation")` writes the error category to DB.■ Fine.■ But the contact-■handler comments still mention "Resend" (`app.■logger.■error("Resend auth fallida.■.■.■")`) post-■v3.■1.■0 SES migration — cosmetic, but log-■grep-■by-■provider will be stale.

4.7 Rate limiting

ID	Severity	Finding
M-■04	Medium	`Limiter` storage is `memory:■/■/■` with `gunicorn -■w 2`.■ Each worker keeps its own counter, so the effective rate is up to 2x configured.■ The code comment acknowledges this and points at SECURITY-■TODO.■ With 2 workers it's still useful; if gunicorn is later scaled up, the limit becomes nearly toothless.■ Move to Redis (ElastiCache `cache.■t4g.■micro` ~$11/■mo) or a DynamoDB-■backed limiter for v3.■2+.
L-■20	Low	`_■client_■ip()` trusts the first entry of `X-■Forwarded-■For` unconditionally.■ Behind ALB this is correct (ALB sets it), but an attacker who hits the EC2 directly (impossible due to SG, but defense-■in-■depth) could spoof.■ Validate via `len(getattr(request, "access_■route", []))` or trust only ProxyFix-■handled values.
POSITIVE	—	Layered rate limits on every sensitive endpoint, with sub-■limits (`5/■min; 30/■hour; 100/■day`) preventing both burst and slow drip.■ Recovery endpoints have explicit 1/■5min and 5/■5min nano-■bucket — good.

4.8 Session management & password handling

Single shared bearer token, no sessions, no passwords. See H-02. The `_recovery_secret()` requirement of `len(secret) >= 16` is a rough sanity check; recovery tokens themselves use `secrets.token_urlsafe(16)` for nonce + HMAC-SHA256 signature + epoch expiry. Stateless and correct.

4.9 Functional/correctness defects with security implications

ID	Severity	Finding
H-■04	High	`s3_■uploader.■is_■configured()` returns False on EC2 because it requires `AWS_■ACCESS_■KEY_■ID` env vars that are intentionally absent (instance role provides creds via IMDS).■ This means `/■api/■admin/■upload-■image` will return 500 ("S3 no configurado…") in production.■ Either remove the access-■key check (rely on boto3 default chain) or call `boto3.■client('s3').■head_■bucket()` as the readiness probe.
M-■16	Medium	`start-■monou.■sh` still exports `RESEND_■API_■KEY` from secrets and the changelog says it's been removed — discrepancy.■ If the field is gone from the secret JSON, the `python3 -■c ".■.■.■['RESEND_■API_■KEY']"` extraction will raise `KeyError` and `set -■euo pipefail` will abort gunicorn boot.■ **Verify** the secret JSON and either delete the line or use `.■get()` semantics.
L-■21	Low	`force_■ipv4` context manager (lines 84-■98) is dead code post-■v3.■1.■0 (no longer called).■ Cosmetic — but dead code accumulates and breeds confusion.

5. Frontend Security (admin/, index.html)

ID	Severity	Finding
POSITIVE	—	Admin token kept in JS-■memory only (`let _■adminToken`), never `localStorage`/■`sessionStorage`.■ Tab refresh forces re-■paste.■ This is the most under-■rated XSS-■mitigation in the codebase.
POSITIVE	—	Admin login form `<input type=■"password">` keeps the token off-■screen /■ out of clipboard-■history natively.
POSITIVE	—	`escapeHtml()` helper used on every dynamic interpolation into `innerHTML` (contact rows, modals, table renders).■ Sample in `app.■js` lines 372-■386 confirms `${escapeHtml(.■.■.■)}` everywhere user data appears.
POSITIVE	—	Recovery URL stripped from `window.■location` immediately on boot via `history.■replaceState({}, "", pathname)` — recovery_■id doesn't survive into history/■screenshots/■Referer.
M-■05	Medium	No CSP header on admin page.■ CDN resources (`cdnjs.■cloudflare.■com`, `cdn.■tailwindcss.■com`, `fonts.■googleapis.■com`) loaded without SRI hashes.■ CDN compromise =■ full admin XSS.■ CSP `default-■src 'self'; script-■src 'self' cdnjs.■cloudflare.■com cdn.■tailwindcss.■com; style-■src 'self' 'unsafe-■inline' fonts.■googleapis.■com; .■.■.■` would harden this materially.

ID	Severity	Finding
M-■06	Medium	No CSP on landing page (`monoulabs.■ai/■`).■ Form posts to `api.■monoulabs.■ai`; a malicious script injected via dependency could exfiltrate form data to a third party.■ CSP `connect-■src 'self' api.■monoulabs.■ai` would block.
M-■07	Medium	No HSTS header (`Strict-■Transport-■Security:■ max-■age=■…; includeSubDomains; preload`).■ CloudFront+ALB serve HTTPS only with redirect from :■80, but a first-■visit MitM on apex `monoulabs.■ai` could downgrade.
L-■22	Low	Admin uses `innerHTML =■ .■.■.■` constructions (lines 372, 411, 470, 671, 957, 1142, 1299, 1530).■ All paths reviewed appear escape-■protected via `escapeHtml`, but the pattern is fragile — one missed call =■ stored XSS in admin.■ Migrating to `textContent` + DOM-■construction or a tagged-■template `safeHtml` helper would harden long-■term.
L-■23	Low	`renderContactDetail` interpolates `c.■error` (line 428).■ Status set by backend to short tags (`auth`, `validation`, `send_■error`, `internal`) — known-■safe — but values trace through DB persistence, so a future code path that writes attacker text to `error` field would store-■XSS via admin.■ Defense in depth:■ keep the `escapeHtml` (which is there).

6. Operational Security

6.1 Deploy pipeline

ID	Severity	Finding
M-■10	Medium	`deploy.■sh` uploads artifact to S3 then triggers SSM Run Command.■ Artifact is **not signed**.■ Anyone with `s3:■PutObject` on `monou-■deploy-■artifacts-■prod` (currently the deployer user, but also any future role with that permission) can substitute a malicious artifact.■ `install.■sh` validates structure (presence of files) but not integrity.■ **Fix:**■ sign artifacts with a long-■lived offline key + GPG-■verify in `install.■sh`, or compute SHA256 client-■side and pass via SSM parameter.
L-■04	Low	`install.■sh` runs as root (implicit, since SSM agent runs as root).■ venv created and pip-■installed packages from PyPI on every deploy.■ No pip hash-■pinning (`requirements.■txt` has version pins but not `-■-■hash=■`).■ PyPI account-■takeover of any transitive dep installs malicious code.■ Pin with `pip-■compile -■-■generate-■hashes`.

ID	Severity	Finding
L-■24	Low	CloudFront Function `monou-■url-■rewriter.■js` is updated manually via AWS CLI per the docs.■ No version control of deployed function code vs `deploy/■cloudfront/■url-■rewriter.■js`.■ Drift risk.

6.2 SSM access

POSITIVE	Session Manager is the access path for both shell and DB port-forward — no SSH keys, no bastion, full CloudTrail audit of every session. Correct.

6.3 monou-vars.sh

ID	Severity	Finding
M-■17	Medium	`monou-■vars.■sh` (per DR doc) is a plaintext shell file on the developer Mac with all infra IDs and the AWS_■PROFILE the CLI uses.■ If the Mac is compromised, the attacker has full topology + the access-■keys path.■ The DR doc recommends "Copia en password manager" but the file itself is plaintext on disk.■ Consider sourcing into a process-■only env (e.■g.■, `direnv` with file-■mode 600) or moving the secrets retrieval into a wrapper that uses `aws-■vault`.

6.4 GitHub branch protection

ID	Severity	Finding
M-■18	Medium	Repository protection for `main` is not documented anywhere in the audit set.■ With AdministratorAccess deploy user + unsigned artifacts + no required reviews on `main`, a single compromised dev machine can push directly + redeploy.■ Enable:■ required PR review (at least self-■review with delay), required status check, required signed commits, restricted push to `main`.

7. Recommendations (prioritized)

Each line: **#. Title — severity / OWASP / effort.** Current state → recommended action.

1. **Scope `monou-landing-deployer` IAM user from AdministratorAccess to least-privilege (~12 actions).** High / A01,A05 / 4-6h. Currently `AdministratorAccess`. Build policy from CloudTrail-of-30d as planned in Fase 9. Consider replacing user with an SSO/SAML-backed role assumption + short-lived session creds via `aws sts assume-role`. Escalate to immediate.
2. **Replace single `ADMIN_TOKEN` with multi-user + bcrypt + sessions (v3.2.0).** High / A07 / 2-3 days. Add per-user audit ("user X edited stat Y at Z"), MFA optional, password reset via the existing magic-link infra, sessions invalidated on logout. Magic-link recovery becomes per-user.
3. **Front `monou-landing-images-prod` with CloudFront/WAF or move to `assets.monoulabs.ai`.** High / A05 / 2-4h. New CloudFront behavior pointing at S3 OAC + cert wildcard already covers the subdomain. Update `s3_uploader.upload()` to return CDN URL. Bonus: edge cache reduces S3 GET cost to near-zero.
4. **Fix `s3_uploader.is_configured()` — drop AWS_ACCESS_KEY_ID env var check, rely on boto3 default chain.** High / A05 / 30 min. Replace with `bool(os.getenv("S3_BUCKET"))` and let `_get_client()` raise `NoCredentialsError` if creds missing. Test admin upload end-to-end after fix.

5. Verify `start-monou.sh` doesn't break boot on the now-missing `RESEND_API_KEY` field. High / A05 / 15 min. Either remove the line or change to `.get('RESEND_API_KEY','')`.

6. Enable CloudWatch Alarms for the Five Sentinels + SNS topic. Medium / A09 / 2-3h. ALB 5xx rate, ALB unhealthy hosts, EC2 StatusCheckFailed, RDS FreeStorageSpace < 5GB, RDS DatabaseConnections > 75%. Email yourself.

7. Enable ALB access logs + S3 access logs + CloudFront standard logging to a `monou-logs` S3 bucket with 30-90d lifecycle. Medium / A09 / 1h. Pennies, mandatory for any forensic timeline.

8. Enable VPC Flow Logs to S3. Medium / A09 / 30 min. Defaults free with S3 standard storage; rotate at 30 days.

9. Enable GuardDuty. Low-Medium / A09 / 5 min toggle, ~$3/mo. The single highest signal-per-effort detection in AWS.

10. Strengthen admin URL field validation: enforce `^https?://` server-side on every `url`/`link_url`/`image_url` upsert. Medium / A04 / 30 min. Prevents `javascript:` and `data:` URI persistence.

11. Add `Strict-Transport-Security` and a permissive-but-real CSP to landing + admin. Medium / A05 / 1-2h. Use report-only first to catch breakage. Suggested CSP for admin: `default-src 'self'; script-src 'self' 'unsafe-inline' cdn.tailwindcss.com cdnjs.cloudflare.com; style-src 'self' 'unsafe-inline' fonts.googleapis.com cdnjs.cloudflare.com; font-src fonts.gstatic.com cdnjs.cloudflare.com; img-src 'self' data: *.amazonaws.com; connect-src 'self' api.monoulabs.ai; frame-ancestors 'none'`. |

12. Add SRI hashes to admin's CDN script tags (Tailwind, FontAwesome, Google Fonts where applicable). Medium / A08 / 30 min. |

13. Enable Secrets Manager rotation for RDS master password (turnkey Lambda) and a quarterly manual rotation for ADMIN_TOKEN/FLASK_SECRET_KEY. Medium / A02,A07 / 1h. |

14. Enable RDS PITR / extend backup retention to 30 days. Medium / A04 / 1 click. |

15. Add Dependabot or equivalent CVE scanning on the GitHub repo for `requirements.txt`. Medium / A06 / 5 min. Critical for catching the next Pillow CVE without manual cadence. |

16. Sign deploy artifacts: SHA256 manifest verified inside `install.sh`. Medium / A08 / 2-3h. Manifest produced by `deploy.sh`, signed with a key in Secrets Manager (or offline), verified server-side. |

17. Migrate Flask-Limiter to Redis-backed storage (ElastiCache `cache.t4g.micro`). Medium / A04 / 2-3h. Fixes the per-worker count drift; required if scaling beyond `-w 2`. |

18. Pin `pip install --require-hashes` via `pip-compile --generate-hashes`. Low / A08 / 1h. |

19. Set BlockPublicAccess at account level (with `monou-landing-images-prod` explicit exception). Low / A05 / 5 min. |

20. Add bucket policy clause `s3:x-amz-content-type ∈ {image/png, image/webp}` on the images bucket. Low / A05 / 15 min. |

21. Replace 8-hex-char content hash with 16-hex (64-bit). Low / A04 / 5 min. |

22. Enable IAM Access Analyzer. Low / A05 / 1 click. |

23. Document GitHub branch protection on `main` and turn on required PR + signed commits. Low-Medium / A08 / 15 min. |

24. Bump KMS key with annual rotation (`aws kms enable-key-rotation`). Low / A02 / 5 min. |

25. Replicate KMS key to a secondary region for DR, or document the trade-off. Low / A02 / 30 min. |

26. Strengthen `FLASK_SECRET_KEY` validator: require ≥ 32 bytes and entropy floor. Low / A02 / 5 min. |

27. Remove dead code (`force_ipv4`, "Resend" log strings) for hygiene. Info / — / 10 min. |

8. Compliance / Audit-Trail Notes

The stack is not in scope of any specific compliance regime today (no PII beyond contact-form leads, no PCI/HIPAA/SOX). For a SOC2-light or "we want to sign enterprise contracts" posture, the gaps that matter most:

SOC2 control area	Current	Gap
CC6 — Logical access	Bearer token + IAM	No per-■user identity, no MFA, no quarterly access review documented
CC7 — System operations	Manual deploy + SSM	No alerting (CloudWatch Alarms), no monitoring evidence, no incident-■response runbook beyond DR doc

SOC2 control area	Current	Gap
CC8 — Change management	Tags + git, atomic deploy	No required-■PR-■review, no signed commits, no change ticket linkage
CC9 — Risk mitigation	KMS, WAF, scoped IAM	No documented risk register, no annual pen-■test, no DR-■test cadence
A1 — Availability	Single-■AZ RDS, single EC2	Single-■AZ DB and one EC2 are availability SPOFs; OK for solo-■dev SaaS posture, document trade-■off
PI1 — Processing integrity	Validation present	No artifact signing, no checksum at install
C1 — Confidentiality	TLS 1.■2, KMS at rest	Plaintext `monou-■vars.■sh` on dev Mac; admin token shared

Minimum viable "first enterprise customer ready" pack (rough ordering): items 1, 2, 6, 7, 11, 13, 23 from §7, plus document an incident-response runbook on top of `DISASTER-RECOVERY.md`, plus annual pen-test (one-shot ~$3-6k from a boutique).

Audit trail strengths to preserve as the stack grows: the AWS-DEPLOY.md / DISASTER-RECOVERY.md / CHANGELOG.md trio is well above industry average for a solo project. Keeping all infra changes captured in versioned markdown is the right pattern; the next step is moving the same content into Terraform/CDK so each `terraform plan` IS a change-management diff. Documented as a future iteration.

Appendix A — Findings Index

ID	Severity	Title	Section
H-■01	High	Deploy IAM user has AdministratorAccess	3.■1
H-■02	High	Single shared ADMIN_■TOKEN, no rotation/■MFA	2 /■ 4.■8
H-■03	High	Public images bucket served without CDN/■WAF	3.■5
H-■04	High	Stale env-■var check breaks image upload on EC2	4.■9
M-■01	Medium	No CloudWatch alarms	3.■7
M-■02	Medium	Admin URL fields accept any string (javascript:■ risk)	4.■1
M-■03	Medium	No CSRF token (mitigated by current bearer-■only)	4.■4
M-■04	Medium	Rate limiter in-■memory drifts across workers	4.■7
M-■05	Medium	No CSP/■SRI on admin	5
M-■06	Medium	No CSP on landing page	5
M-■07	Medium	No HSTS header	5
M-■08	Medium	No automated CVE scanning	2 (A06)
M-■09	Medium	Recovery flow =■ inbox-■access ≡ admin	2 (A07)
M-■10	Medium	Deploy artifacts not signed	6.■1

ID	Severity	Title	Section
M-■11	Medium	No Secrets Manager auto-■rotation	3.■4
M-■12	Medium	Image bucket missing content-■type bucket-■policy clause	3.■5
M-■13	Medium	RDS backup retention only 7 days	3.■6
M-■14	Medium	No PITR cadence	3.■6
M-■15	Medium	ALB access logs not enabled	3.■7
M-■16	Medium	start-■monou.■sh references removed RESEND_■API_■KEY	4.■9
M-■17	Medium	monou-■vars.■sh stored plaintext on dev Mac	6.■3
M-■18	Medium	GitHub branch protection not documented	6.■4
L-■01	Low	KMS auto-■rotation not enabled	2 (A02)
L-■02	Low	No documented KMS/■secrets rotation schedule	2 (A02)
L-■03	Low	8-■hex content hash for S3 keys	4.■1
L-■04	Low	pip install without hash pinning	6.■1
L-■05	Low	No VPC Flow Logs	3.■3
L-■06	Low	No CloudFront access logs	3.■7
L-■07	Low	IAM Access Analyzer not enabled	3.■1
L-■08	Low	No Access Key rotation automation	3.■1
L-■09	Low	KMS key single-■region	3.■2
L-■10	Low	Backend SG egress unrestricted	3.■3
L-■11	Low	No VPC endpoints	3.■3
L-■12	Low	FLASK_■SECRET_■KEY length check is weak	3.■4
L-■13	Low	Images bucket versioning unverified	3.■5
L-■14	Low	No account-■level Block Public Access	3.■5
L-■15	Low	Manual snapshots not automated	3.■6
L-■16	Low	GuardDuty not enabled	3.■7
L-■17	Low	CloudTrail retention only 90d	3.■7
L-■18	Low	Plain-■text email body not escaped	4.■3
L-■19	Low	Stale "Resend" string in logger calls	4.■6
L-■20	Low	X-■Forwarded-■For trusted unconditionally	4.■7
L-■21	Low	Dead code:■ force_■ipv4 ctx mgr	4.■9
L-■22	Low	innerHTML pattern is fragile	5
L-■23	Low	error field interpolation in admin modal	5
L-■24	Low	CloudFront Function deployment not in CI	6.■1

End of report.